

CHAPTER 3

METHODOLOGY

This chapter explains in depth the proposed SECS/GEM security mechanism referred to as SECS/GEM with Authenticated Encryption (SECS/GEM-AE). Control information used by SECS/GEM-AE is carried with every message. The control information is a core part of SECS/GEM-AE as it is essential to authenticate messages and check if they have not been changed during transmission. The control information is piggybacked with every SECS/GEM message so as not to change the original message structure of SECS/GEM messages.

The proposed mechanism consists of three stages: Stage 1, Authenticated Encryption; Stage 2, Control Information Generation; and Stage 3, Decryption and Authentication. In the first stage, the message is encrypted, and authentication information is generated for verification at the receiver's side. This stage accomplishes the first and second objectives of the study. In the second stage, control information is attached to the message. In the third stage, the receiver utilizes the control information to decrypt and authenticate the message. Detailed discussions of these stages are provided in the following sub-sections.

The remainder of this chapter is structured as follows. Section 3.1 discusses the proposed mechanism's methodology, assumptions, and threat model. The proposed mechanism, its components, control information, and underlying mechanisms are presented in Section 3.2. The workflow of the proposed mechanism is discussed in Section 3.3; Section 3.4 explains the assessment methods and measures. Section 3.5 summarizes the entire chapter.

3.1 Developing the SECS/GEM-AE Mechanism: Methodology and Approach

SECS/GEM-AE intends to provide a viable security mechanism capable of providing data confidentiality and ensuring the authentication of SECS/GEM messages. Data confidentiality ensures unauthorized devices can no longer read the SECS/GEM message payload. Only legitimate messages are processed through message authentication, and any altered messages will automatically be dropped.

3.1.1 Underlying Assumptions for the Proposed Mechanism

Several assumptions are made for developing a comprehensive security mechanism designed to fulfill this study's research objectives and validate the anticipated results. The following assumptions are made.

- As the SECS-I protocol is obsolete and only survives on older machines, this research is confined to using the HSMS protocol.
- In order to assess the functionality and performance, all industrial network participants (hosts and equipment) are anticipated to be set up with the proposed mechanism i.e., SECS/GEM-AE mechanism. This is important because the message contents are encrypted, due to which the recipient cannot understand and would discard message.
- Since the proposed mechanism uses symmetric encryption algorithm, which requires a secret key to encrypt and decrypt the message before processing it. The sender and the receiver must possess the same secret key to decrypt and verify the authenticity of a received message. This requirement is met by the SECS/GEM-AE, where the secret keys are preloaded on the communicating devices during initialization. Thus, in this study, it is assumed that participating nodes are preconfigured with the required keys.

3.1.2 Assessing Security Risks: The Threat Model for the SECS/GEM-AE

The threat model is described as follows to present a comprehensive security mechanism that achieves the objectives specified in Section 1.4:

1. The attacker can monitor network traffic and knows the network port used by the host and equipment.
2. The attacker has knowledge of SECS/GEM messages (streams and functions) and binary encoding, enabling the attacker to read messages and passively collect sensitive data.
3. The attacker can inspect messages between the two interacting entities and send crafted or modified messages with malicious intent.

3.1.3 Design Goal of the SECS/GEM-AE Mechanism

Due to the lack of security features in standard SECS/GEM and the shortcomings of existing SECS/GEM security mechanisms, a new security mechanism that meets the research objectives provided in Chapter 1 is required. The literature review reveals various issues in SECS/GEMsec, designed to protect SECS/GEM communications. Based on the literature review in Chapter 2, the criteria for developing a new security mechanism for SECS/GEM communications in the industrial network are as follows:

1. **Lightweight:** The lightweight requirement can be met by simplifying the existing data confidentiality and message authentication procedures. As SECS/GEMsec, which uses SHA-256 and RSA to ensure authentication, requires much processing time, an authenticated encryption function can reduce its complexity. Thus, the mechanism is

much lighter and more efficient as it removes the need for RSA and the manual configuration of three separate keys for SHA-256 and RSA on each computer of the industrial network.

2. **Multi-featured Solution:** The SECS/GEMsec mechanism only provides authentication. A robust system should provide multiple security features in one solution; the proposed mechanism combines multiple features like data confidentiality and message authentication.

3.2 Design of the Proposed SECS/GEM-AE Mechanism

The proposed SECS/GEM-AE mechanism protects industrial network communications to achieve the research objectives in Chapter 1 (data confidentiality and authentication). This section describes the mechanism's primary stages, processes, and components. Figure 3.1 shows the proposed mechanism's operating layer in SECS/GEM architecture.

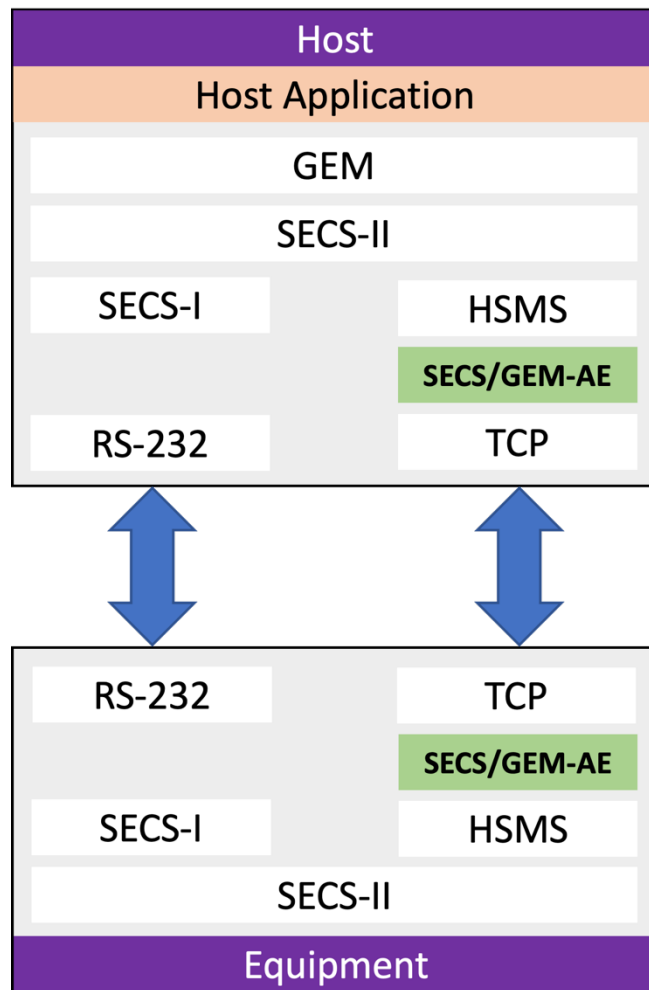


Figure 3.1 Proposed Mechanism's Operating Layer in SECS/GEM Architecture

The proposed SECS/GEM-AE mechanism has three stages. The first is the authenticated encryption mechanism. In this stage, the SECS/GEM message is fed into the authenticated encryption mechanism to generate the encrypted data and tag. Stage 2 is control information generation. In this stage, the control information is generated to authenticate communications. Stage 3 is achieving message authentication. This stage determines if messages are authentic or illegitimate. Figure 3.2 displays the SECS/GEM-AE security mechanism's stages.

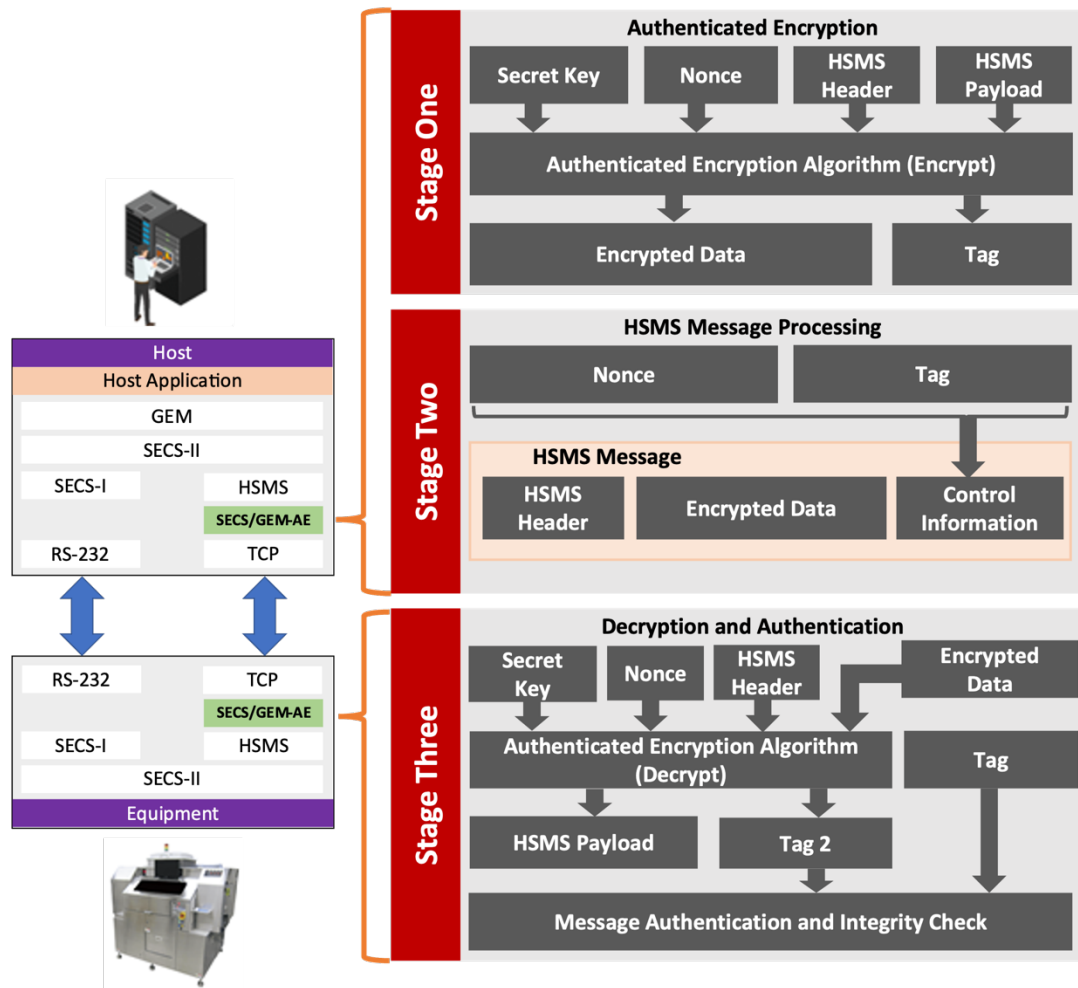


Figure 3.2 SECS/GEM-AE Mechanism Stages

3.2.1 Authenticated Encryption (Stage 1)

This stage aims to achieve the first objective of this research, which is to exchange encrypted SECS/GEM messages rather than plaintext messages to protect sensitive information within SECS/GEM communications in the manufacturing environment. A desired authentication encryption scheme is used to achieve this goal. This research utilizes the AES-GCM algorithm to encrypt the messages and produce tags to verify and authenticate the messages.

In the first stage, the secret key, pseudorandom nonce, plaintext data to be encrypted, and associated data to be authenticated are given as input to the encryption algorithm. In this case, the message payload is encrypted while the message header is

used as associated data which is only authenticated and not encrypted. The encrypted message payload and the verification tag are generated as output. The encrypted message payload replaces the message payload. Figure 3.3 depicts the Host, Equipment, and SECS/GEM-AE configuration used. The configuration includes IP address, port, mode of operation, algorithm used, and secret keys. The secret keys (K1, K2) used by the host and equipment are installed in the host and the respective equipment. The host maintains a list of equipment (E1, E2) and maps the respective key (K1, K2) to each equipment.

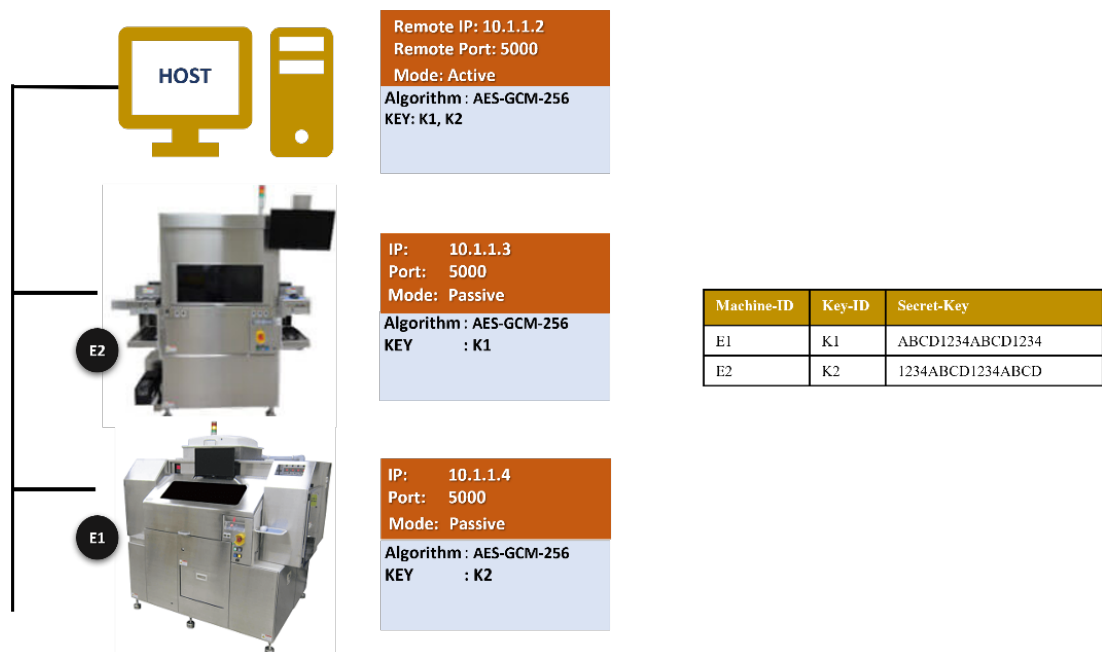


Figure 3.3 Host and Equipment with SECS/GEM-AE Configuration

Thus, the first and second objectives of this study are achieved. The verification tag is essentially a hash of the message header and payload. This tag will be used at the receiver's side to authenticate the message and verify its integrity. Thus, the first objective of this study is achieved. The message payload is also encrypted, making the data in the message payload confidential and therefore achieving the second objective of this study.

3.2.2 Message Processing and Control Information (Stage 2)

The control information is at the core of the proposed mechanism. It includes all necessary information to resolve security flaws of standard SECS/GEM communications and issues in existing security mechanisms. The control information comprises Nonce and Tag that the receiver requires to decrypt the message and ensure message authenticity. The structure of the control information is depicted in Figure 3.4.

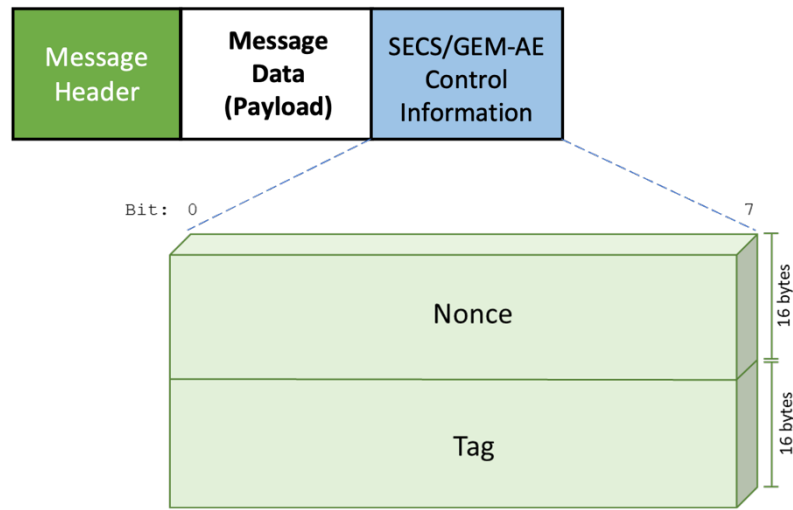


Figure 3.4 Control Information Structure

- **Nonce Field:** This 16-byte field contains the pseudorandom nonce used by the authenticated encryption used with SECS/GEM-AE. This nonce value is required at the receiver to decrypt the message payload.
- **Tag field:** This 16-byte header field contains the Tag generated by the encryption scheme. The receiver uses the Tag to verify the authenticity of the message.

3.2.3 Decryption and Message Authentication (Stage 3)

The receiver must decrypt and verify the integrity of the message payload for data messages before accepting them. It is important to note that this process does not apply to control messages since they do not contain any payload. This stage is about

decrypting the message and authenticating the message. The first step is to extract the information contained in the control information, i.e., nonce and tag. The nonce is used as an input for the decryption process. The tag is used to verify the message's authenticity and integrity at the end of the decryption process.

The secret key, nonce, encrypted payload, and message header (as associated data) are input for the decryption algorithm. The encrypted payload is decrypted to its original form, and at the end of the decryption process, the receiver regenerates a tag (Tag2) using the same key. Suppose the generated tag (Tag2) matches the tag that arrived with the received message. In that case, the message is considered authentic, ensuring no changes have occurred during transit and message integrity is maintained. However, the message is dropped if there is a mismatch between the tags.

3.3 SECS/GEM-AE Workflow

The SECS/GEM request messages are processed at the sender and the commands are packaged in the specified SECS/GEM structure. Once this stage is complete, the proposed mechanism comes in the action and intervene and takes this data as input before the data is transferred to the destination. Once the input is available to the sender, the rest of the details of the workflow of the proposed mechanism are listed below:

1. Extract SECS/GEM Header: SECS/GEM-AE only checks the SECS/GEM header's integrity while encrypting the message payload. The sender needs to extract the SECS/GEM header to be used as associated data during the encryption process.

2. Extract SECS/GEM Payload: The SECS/GEM messages are of two types: control messages and data messages. The control messages are usually comprised of the header only; thus, these messages must be authenticated. In contrast, the data messages usually have a payload, which must be encrypted. Thus, the sender must extract the payload and process it differently from the header.
3. Retrieve Secret Key: Dependent upon the algorithm selected, the secret size may vary; thus, the right key must be selected for the encryption and authentication process. The host usually connects with more than one piece of equipment at a time; hence, the right key must be chosen based on the communicating equipment.
4. Generate Random Nonce: The pseudo-random number (nonce) used to initialize the encryption algorithm is generated next.
5. Encryption Process: The process of encryption involves using an encryption algorithm, such as AES-GCM with a preferred key size, to encrypt the message payload data. The message header is used as associated data input, which is only authenticated. The Secret Key and Nonce are used in this process.
6. Authentication Tag: Upon the completion of the encryption process, the encrypted payload and a tag (Tag1) will be generated by the given algorithm, which the receiver requires to authenticate the received message.

7. Replace Message Payload: Once the header and data contained in the SECS/GEM message are processed, the SECS/GEM message payload is replaced with the encrypted payload.
8. Append Control Information: The nonce and tag obtained in steps 5 and 7 are appended to the SECS/GEM message as control information so that the receiver can use the nonce to decrypt and verify the message. The SECS/GEM header's first 4 bytes contain the length of the message. The proposed mechanism uses the value stored in this field and places the control information at length + 1 location. This way, the control information is appended to the messages and is carried out by the message itself as piggybacked.
9. Send SECS/GEM message: The control information is piggybacked with the message; thus, the message data confidentiality and authentication are achievable without using separate control messages exchanged between the sender and the receiver.
10. Check Control Information: Upon receiving the message, it is only processed if it has control information; otherwise, the message is discarded.
11. Processing Received Message: Upon receiving a SECS/GEM-AE message, the receiver must first extract the SECS/GEM header, encrypted payload, and control information contained in the message. The nonce, tag, header, and encrypted payload are extracted from the message and saved in temporary variables.

12. Retrieve Secret Key: Dependent upon the key size configured, the secret key may vary; thus, the right key must be selected for the decryption and authentication process.
13. Decryption Process: Decrypt encrypted payload with the decryption algorithm (e.g., AES-GCM with preferred key size), Secret Key, and Nonce using Header as input for associated data.
14. Authentication Tag: Upon completion of the decryption process, the original message payload and a tag (Tag2) will be generated by the given algorithm. The receiver requires this tag to authenticate the received message.
15. Message Authentication: Verify tag (Tag2) generated from decryption with the tag (Tag1) extracted from the control information. If both tags match, the message is valid, or else, the message is invalid.
16. Accept/Reject Message: If the message is valid, the encrypted payload is replaced with the original message payload (obtained after decryption). The control information is removed, and the message is processed. If the message is invalid, the message is dropped.

The proposed mechanism uses authenticated encryption. The message payload is encrypted, while the message header is used as associated data (authenticate only). For every message, a random 16-byte nonce is generated for encryption. Once encryption is complete, the encrypted message payload and a tag (Tag1) are generated. The receiver uses this tag to verify the integrity of the message. The message payload

is replaced with the encrypted payload. The nonce and the tag are attached at the end of the message as control information. The message is then sent to the receiver.

The receiver checks the message for the control information and discards it if it is absent. The nonce and tag (Tag1) are extracted from the control information. The receiver decrypts the encrypted payload using the message header as associated data (authenticate only). The nonce present in the control information is also used as input for decryption. The decryption yields the original message payload and a tag (Tag2). If the tag from the message's control information (tag1) matches the tag generated after decryption (Tag2), the message is considered authentic and valid. If the message is valid, the control information is removed from the message, and the encrypted payload is replaced with the original message payload and accepted. If the message is not valid, it is discarded. Figure 3.5 depicts the workflow of the proposed mechanism.

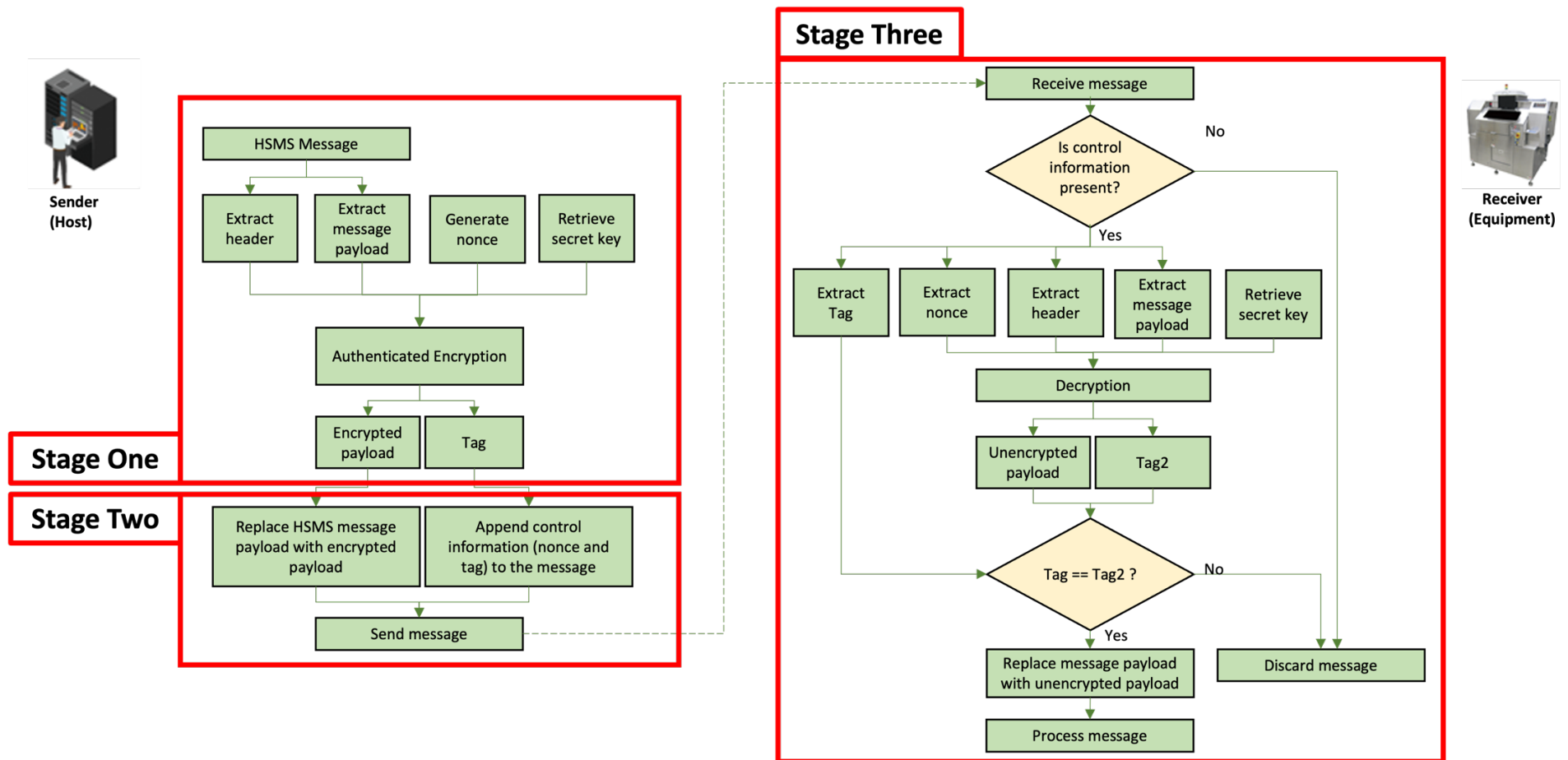


Figure 3.5 Proposed Mechanism Workflow

3.4 Designing Testbed Environment and Assessing Performance

This phase aims to design a testbed environment where the proposed mechanism can be evaluated using different assessment metrics. The experiments aim to determine the processing speed, efficiency, and functioning of the proposed mechanism.

3.4.1 Testbed Design

The proposed mechanism aims to enhance the security of SECS/GEM communication in industrial networks, which often have critical and sensitive equipment vulnerable to cyber-attacks. In this testbed design, the network topology consists of a host, equipment, and a switch. The testbed is designed similar to the related work (S. U. A. Laghari, Manickam, Al-Ani, et al., 2021a). The host and equipment are equipped with the proposed mechanism and set up to log information to evaluate the processing time. The network traffic is captured using Wireshark to dissect and analyze the contents of the messages from an attacker's perspective. The goal is to collect data, analyze and compare the results obtained from the proposed mechanism with other existing mechanisms to determine its effectiveness in enhancing the security of SECS/GEM communications in industrial networks.

3.4.2 Evaluation Matrices

Various assessment metrics are utilized to assess if the proposed SECS/GEM-AE mechanism meets the requirements of this study and to evaluate the proposed SECS/GEM-AE mechanism. These measurements include processing time and control overhead incurred with each message transmitted, which were also used for evaluating the related work (S. U. A. Laghari, Manickam, Al-Ani, et al., 2021a).

3.4.3 Processing Time

Performance is the most important aspect of SECS/GEM because it provides real-time insights into the equipment for effective monitoring, regulation, and decision-making. The SECS/GEM standard states that reports can be generated at a frequency of 1Hz (i.e., one report cycle per second), and there are implementations in which this frequency is 10Hz (Weber, 2016), resulting in ten reports per second. The ultimate design purpose of the SECS/GEM protocol is performance; hence, any mechanism that brings up security features must also be very efficient to impact performance as little as possible. Assessment of the complexity of a security system can be based on the time required to complete the specified task (Bayılmış et al., 2022). Generally, a more complex mechanism is less efficient and harder to maintain.

In contrast, a less complex mechanism can function more efficiently and takes less processing time, incurring less cost on the resources. This study adds message data confidentiality and authentication to SECS/GEM communications in an industrial network for data and control messages transferred between the host and equipment using a less sophisticated and easily deployable mechanism, one of the study's design criteria. Consequently, it is necessary to evaluate the complexity of the proposed method and the behavior of the processes involved in providing security characteristics.

Even though SECS/GEM messages are classified as control and data messages, the sender and receiver of both messages must perform the same steps. The steps include generating a request message on the sender, verifying the request message on the receiver, generating a response message, and verifying the message on the receiver.

In SECS/GEM-AE messages, the sender must encrypt the message payload and generate a tag for verifying the message at the receiver. The control information with

its required fields (nonce, tag) is then appended to the message. Deducting the ending time (TS_{end}) from the starting time (TS_{start}) of the mentioned processes gives the processing time (PT) at the sender side. The processing time at the sender is calculated using 3-1.

$$PT = TS_{end} - TS_{start} \quad 3-1$$

Applying the equation at the sender, PT is the processing time (in milliseconds) for sending messages, TS_{end} is the ending time of generating the SECS/GEM-AE messages at the sender, and TS_{start} is the start time of generating the SECS/GEM-AE message.

Upon receiving a control or data message, the receiver (i.e., the host or the equipment) should decrypt (in case of data message) and perform verification of the message to prevent the injection of spoofed messages that could interrupt the communication between a host and its equipment. For SECS/GEM-AE, the receiver must confirm the presence of the control information on the message before starting with the decryption and message verification. The processing time PT is measured at the receiver's end by subtracting the ending time (TS_{end}) from the starting time(TS_{start}) for the message decryption and verification. The time required to verify SECS/GEM-AE messages at the receiver is computed using 3-1, where PT is the processing time (in milliseconds) at the receiver that needs to verify the SECS/GEM-AE message. TS_{end} is when the verification is completed, and TS_{start} is when the verification is at the receiver.

3.4.4 Control Information Overhead

SECS/GEM-AE appends control information to all messages transmitted by the sender; hence, it adds overhead to each message exchanged between a sender and receiver. The control overhead also adds complexity (Bayılmış et al., 2022), therefore

it is also measured for evaluating SECS/GEM-AE. The control information has a fixed size of 32 bytes, sufficient for piggybacking necessary control data. The control overhead (CO) incurred by SECS/GEM-AE is computed as follows:

$$CO = \frac{CI_{size}}{Message_{size} + CI_{size}} \quad 3-2$$

Where CO is the message overhead computed for each message transmitted or received by SECS/GEM-AE enabled host or equipment, CI_{size} is the size of the control information, and $Message_{size}$ is the size of a standard SECS/GEM message (i.e., control or data message).

3.5 Chapter Summary

This chapter explains the design of the SECS/GEM-AE mechanism for securing SECS/GEM communications in the ecosystem of Industry 4.0 and serves as the core of this research. The SECS/GEM-AE mechanism intends to satisfy the primary design objectives described in Chapter 1 (i.e., to provide data confidentiality, and authenticate messages). The proposed mechanism introduces a set of control information appended to each message and used by the receiver to authenticate and verify the message.

This chapter also included a comprehensive discussion of the theoretical capabilities of the proposed security mechanism's underlying architecture. The proposed SECS/GEM-AE mechanism enables authenticated entities to communicate over an industrial network. The proposed mechanism ensures that messages are not altered in transit and prevents adversaries from obtaining sensitive information in SECS/GEM communications. Experiments are conducted as part of the evaluation process to demonstrate the proposed mechanism's effectiveness and applicability.

Chapter 4 examines the proposed SECS/GEM-AE mechanism's design and implementation details.